

**Service Système Information & Communication
Sécurité des Systèmes d'Information**

**Analyse de risques cybersécurité
SI Luminis Eclairage**

CONFIDENTIEL

Ce document ne doit être communiqué qu'aux personnes habilitées à en connaître.

Rédacteur : Julien CHARPENTIER - TechNova
Version du 12/05/2025

Références

Documents	Auteur	Commentaires ¹
Guide EBIOS RM	ANSSI	
Fiches méthode EBIOS RM	ANSSI	
Documentation LUMNIS ECLAIRAGE	LUMINIS	
Entretiens	LUMINIS	

Versions

Date	Auteur	Modification ²	Commentaires ³
	J. CHARPENTIER	Création	Formatage et données de base LUMINIS
	J. CHARPENTIER	Modification	Exploitation atelier 1 (VM, BS, ER)
	J. CHARPENTIER	Modification	Conformité guide d'hygiène informatique
	J. CHARPENTIER	Modification	Conformité RGPD
	J. CHARPENTIER	Modification	Relecture, fiches de risques résiduels
	J. CHARPENTIER	Modification	Relecture & corrections

¹ Nature des modifications et autres informations utiles

² Création, Modification, Validation

³ Nature des modifications et autres informations utiles

PREAMBULE

L'objet de ce document est de présenter les résultats de l'analyse de risque conduite chez LUMINIS ECLAIRAGE avec la méthode EBIOS Risk Manager. Le plan d'action, également appelé plan de traitement des risques (PTR), sera intégré dans la PSSI de LUMINIS ECLAIRAGE.

Le plan d'action est présenté dans un document séparé appelé "luminis_plan_actions.pdf".

La méthode EBIOS RM ne prend normalement en compte que les sources de risques malveillantes. Afin de conduire une analyse de risque plus exhaustive, les sources de risques accidentelles et naturelles ont été étudiées dans le cadre de l'atelier 1 (Détermination du socle de sécurité).

Au regard du contexte de cette 1^{ère} analyse de risque et du niveau de menaces, l'approche par conformité a été retenue. Seuls les ateliers 1 (cadrage et socle de sécurité) et 5 (traitement du risque) ont été réalisés.

(DANS LE CADRE DE LA JOURNÉE DÉDIÉE À LA GESTION DES RISQUES, LES 5 ATELIERS SERONT PARCOURUS)

OBJECTIF DE L'ÉTUDE	ATELIERS PRINCIPAUX À CONDUIRE OU EXPLOITER				
	1	2	3	4	5
Identifier le socle de sécurité adapté à l'objet de l'étude	X				
Être en conformité avec les référentiels de sécurité numérique	X				X
Évaluer le niveau de menace de l'écosystème vis-à-vis de l'objet de l'étude			X (note 1)		
Identifier et analyser les scénarios de haut niveau, intégrant l'écosystème		X	X		
Réaliser une étude préliminaire de risque pour identifier les axes prioritaires d'amélioration de la sécurité	X (note 2)	X	X (note 3)		X (note 4)
Conduire une étude de risque complète et fine, par exemple sur un produit de sécurité ou en vue de l'homologation d'un système	X	X	X	X	X
Orienter un audit de sécurité et notamment un test d'intrusion			X	X	
Orienter les dispositifs de détection et de réaction, par exemple au niveau d'un centre opérationnel de la sécurité (SOC)			X	X	

1. CADRAGE ET SOCLE DE SÉCURITÉ

1.1 Cadre de l'étude

La présente étude a pour but de :

- Améliorer la sécurité du système d'information de LUMINIS ECLAIRAGE au regard des différentes sources de risques auxquelles la société peut être exposée dans son environnement opérationnel ;
- Permettre la mise en conformité vis-à-vis de la réglementation RGPD ;
- Fournir les éléments nécessaires à la rédaction d'une première version de la Politique de Sécurité des Systèmes d'Information (PSSI) de LUMINIS ECLAIRAGE.

Il s'agira de :

- Identifier les risques de non-conformité par rapport au RGPD,
- Identifier et d'apprécier les risques opérationnels,
- Identifier les mesures de sécurité permettant de traiter les risques.

Le périmètre de l'étude prendra principalement en compte **l'activité de fabrication (Direction Production & Logistique), l'activité commerciale (Direction Commercial) et l'activité de support (Direction Installation & Maintenance)**.

Cette étude a été réalisée pendant la période du ... au

L'étude a mobilisé les personnes suivantes :

- Direction générale : Jean DUPONT (PDG), Claire MOREL (DG)
- Accueil & secrétariat : Marie LEFRANC (responsable)
- Direction commerciale : Nadia BENAMARA (responsable),
- Direction Production & Logistique : Pierre DURAND (responsable), Stéphane MARTIN (QSSE)
- Direction Installation & Maintenance : Thomas LEROY (responsable)
- Agence de Paris : Hélène RICHOUX (coordinatrice)
- Services informatiques : Julien LAMBERT (RSI)

L'étude a été réalisée à partir de la documentation existante, la conduite d'entretiens avec les personnes citées ci-dessus. Comme cela a été évoqué dans le préambule, il a été réalisé deux ateliers : cadrage et socle de sécurité, traitement du risque.

Il n'a pas été possible de rencontrer ... qui a développé les applications nécessaires à son activité. Cette partie du SI est peu documentée (aucune cartographie de l'architecture : composants, flux, données ...) mais elle a été au mieux prise en compte à partir des quelques informations disponibles et des informations fournies par les responsables du SI.

1.2 Périmètre métier et technique

Cette partie a pour objectif de décrire les missions réalisées par le système dans son environnement opérationnel en détaillant les valeurs métier et les biens supports mis en œuvre.

1.2.1 Présentation de la société LUMINIS ECLAIRAGE

LUMINIS ECLAIRAGE est une PME industrielle (PMI) créée en 2005. Elle est implantée en périphérie de Metz. Elle est spécialisée dans **la conception, la fabrication, l'installation et la maintenance de systèmes d'éclairage technique**.

Forte de **80 salariés**, LUMINIS ECLAIRAGE intervient principalement au profit de **collectivités locales** et de **clients industriels** pour fournir des **solutions d'éclairage intelligent, durable et personnalisable**.

L'entreprise s'organise autour de **trois grandes activités opérationnelles** :

- **La production et la logistique** : fabrication et gestion des approvisionnements en lien avec les fournisseurs et l'atelier de production ;
- **L'installation et la maintenance** : déploiement sur site des solutions, supervision, suivi et service après-vente des systèmes livrés ;
- **Le développement commercial** : relation client, appel d'offre, devis & commandes, suivi du client et de sa satisfaction.

Ces trois domaines reposent sur un **système d'information structuré mais hétérogène**, comprenant :

- Des applications métiers critiques (ERP, CRM, outils qualité, paie, etc.),
- Des **outils bureautiques ou non maîtrisés** (Excel, Trello, WhatsApp),
- Une **infrastructure locale vieillissante** (serveurs physiques en local, fichiers partagés sur NAS),
- Des **services cloud non centralisés**.

Ce **système d'information est géré de manière fragmentée**. Le responsable informatique interne, plusieurs référents métier et des prestataires externes assurent son exploitation. La **documentation technique et organisationnelle est lacunaire**. Elle est souvent propre à chaque service.

Sur le plan de la sécurité informatique, **aucune gouvernance claire n'est en place**. La **répartition des responsabilités est floue**, les **politiques d'accès sont mal définies**, et les **outils existants sont sous-exploités** (pas de segmentation réseau, accès VPN sans MFA, absence de supervision).

Face à ces constats dont l'entreprise est consciente, LUMINIS ECLAIRAGE a sollicité le cabinet TechNova pour conduire une **analyse de risques centrée sur trois activités métiers critiques** :

- **Production & logistique** (continuité d'activité, traçabilité, flux de fabrication),
- **Installation & maintenance** (relation client, intervention sur site, IoT),
- **Commercial** (CRM, commandes, image de marque, confidentialité).

Cette démarche a pour but d'**identifier les vulnérabilités majeures**, d'**identifier et de prioriser les risques SI**, et de **proposer des mesures de traitement adaptées**.

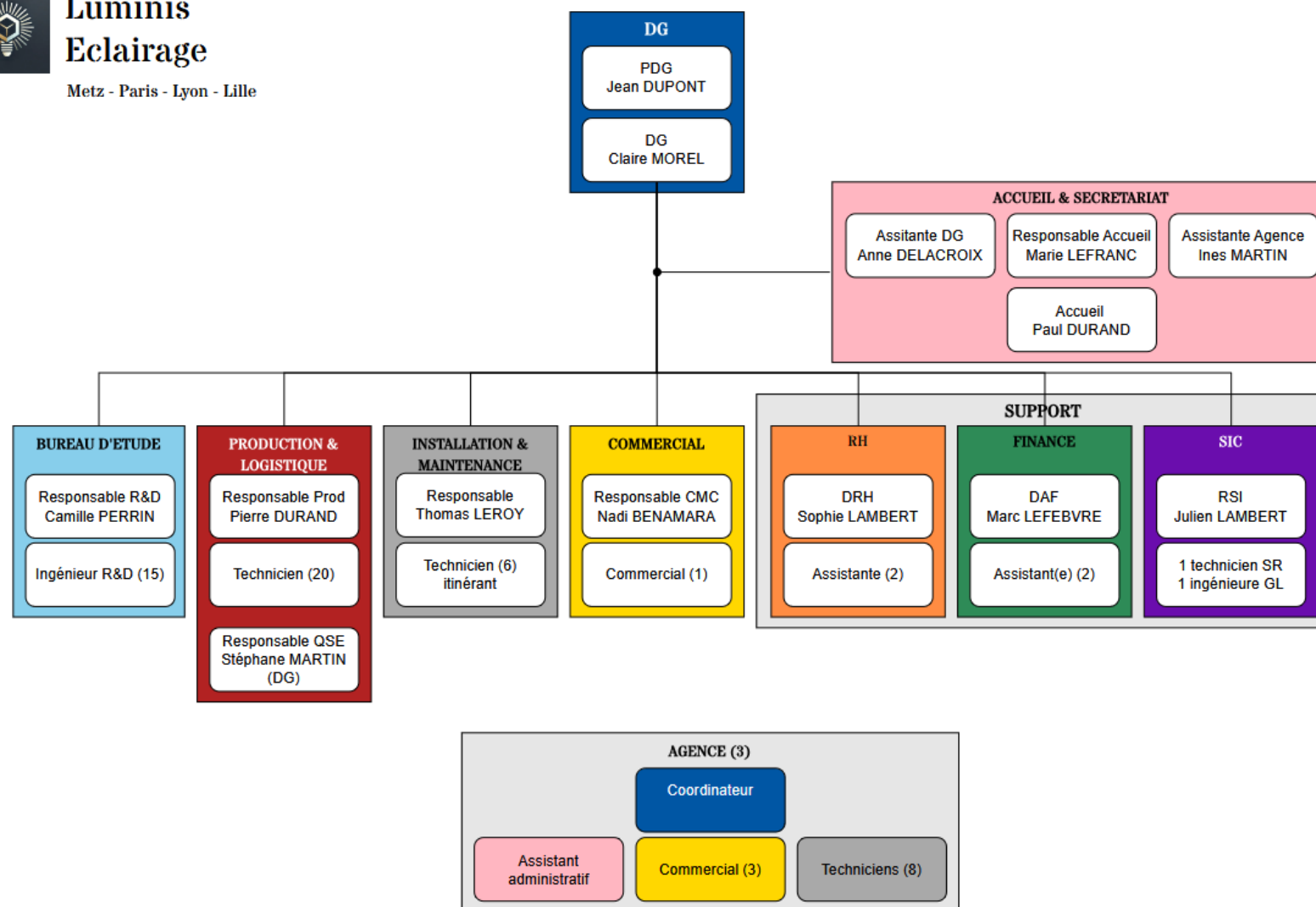
Les hypothèses concernant l'environnement de travail et la sécurité se trouvent les annexes n°3 (Guide d'hygiène) et n°4 (RGPD). Elles ont été formulées à l'occasion de l'atelier n°1 - activité n°4 qui concerne le socle de sécurité.

ORGANIGRAMME DE LUMINI ECLAIRAGE (2024)



**Luminis
Eclairage**

Metz - Paris - Lyon - Lille



Mise à jour: 20/01/2024
Auteur: Anne DELACROIX

1.2.2 Valeurs Métier (à numéroté)

Une valeur métier est un processus ou une information nécessaire au système pour accomplir sa mission. Les descriptions des valeurs métier de type « processus » et « informations » ainsi que leurs besoins de sécurité sont listés dans le tableau donné ci-après.

[L'annexe n°1](#) présente les métriques utilisées pour la définition des besoins de sécurité

Activité	Valeur métier	Nature	Description
Production & Logistique	Traçabilité des composants	Information	Références, lots, fournisseurs, historiques
Production & Logistique	Planification de production	Processus	Ordonnancement, priorités de production
Production & Logistique	Commandes fournisseurs	Processus & Information	Demandes d'achat, validation, suivi
Production & Logistique	Suivi de fabrication	Information	Historique des fabrications et contrôles qualité
Production & Logistique	Données de stock	Information	Seuils, mouvements, inventaires
Installation & Maintenance	Historique client et produit	Information	Suivi des équipements installés et incidents
Installation & Maintenance	Organisation des interventions	Processus	Planification des techniciens, urgences
Installation & Maintenance	Suivi des non-conformités terrain	Information	NC terrain ou client, plans d'action
Installation & Maintenance	Données SAV	Information	Tickets, photos, rapports d'intervention
Installation & Maintenance	Communication client-tech	Processus	WhatsApp, téléphone, mails informels
Commercial	Données clients & contrats	Information	Identité, historique, conditions commerciales
Commercial	CRM et gestion des commandes	Processus & Information	Suivi des devis, commandes, factures
Commercial	Image de marque	Information	Réputation, avis, positionnement marché
Commercial	Communication client	Processus	Emailing, réponses aux appels d'offres

1.2.3 Biens supports (Non exhaustif)

Un bien support est une composante du système d'information sur laquelle repose une ou plusieurs valeurs métier. Un bien support peut être de nature numérique, physique ou organisationnelle.

Bien support	Catégorie	Description	Responsable	Valeurs métier associées
Serveur physique SRV-DC01	Serveur	Héberge les VM ERP, CRM, Comptabilité	Julien Lambert (RSI)	ERP, CRM, Compta
Serveur physique SRV-DC02	Serveur	Héberge les VM GMAO, Support, BDC	Julien Lambert (RSI)	GMAO, Support, Domaine
SRV-PDC	Contrôleur de domaine	Serveur d'annuaire principal	Julien Lambert (RSI)	Gestion des accès
SRV-ERP01	Application / Serveur applicatif	ERP Odoo pour gestion prod et commandes	Julien Lambert (RSI)	Production, Logistique, Commercial
SRV-CRM01	Application / Serveur applicatif	CRM Webforce pour suivi clients	Julien Lambert (RSI)	Commercial
SRV-CPT01	Application / Serveur applicatif	Sage Comptabilité	Julien Lambert (RSI)	Finance
SRV-GMAO	Application / Serveur applicatif	GMAO Locative	Julien Lambert (RSI)	Maintenance
SRV-SUPPORT	Application / Serveur applicatif	GLPI (non utilisé)	Julien Lambert (RSI)	Support informatique
Pare-feu Stormshield SN160	Équipement de sécurité	Protection périmétrique, accès internet	Julien Lambert (RSI)	Tous
Switch Netgear/Cisco	Équipement réseau	Distribution réseau LAN	Julien Lambert (RSI)	Tous
Téléphones IP	Téléphonie IP	Communication interne et client	Julien Lambert (RSI)	Tous services
Postes fixes et portables	Terminal utilisateur	Accès aux applications et données métiers	Julien Lambert (RSI)	Tous services

Bien support	Catégorie	Description	Responsable	Valeurs métier associées
Excel (production/logistique)	Application bureautique	Suivi approvisionnement et stock hors ERP	Pierre Durand	Production, Logistique
Outlook	Service de messagerie	Communication interne et avec fournisseurs	Tous	Tous services
QMS CloudCert	Application qualité	Documentation qualité & non-conformités	Stéphane Martin	Qualité
Trello / Notion	Application supervisée non	Suivi personnel des plans d'action	Stéphane Martin	Qualité
WhatsApp	Messagerie instantanée	Réception informelle de réclamations clients	Support SAV	Installation & maintenance
Eurécia	Application RH	Gestion RH (absences, entretiens...)	Sophie Lambert	Ressources humaines

1.2.4 Synthèse du périmètre métier et technique

Activité (mission)	Nom VM	Nature VM	Responsable VM	Nom BS	Responsable BS
Production & Logistique	Traçabilité des composants	Information	Pierre Durand	SRV-ERP01	Julien Lambert
	Planification de production	Processus			
	Commandes fournisseurs	Processus & Information			
	Suivi de fabrication	Information			
	Données de stock	Information			
Installation & Maintenance	Historique client et produit	Information	Thomas Leroy	SRV-GMAO	Julien Lambert
	Organisation des interventions	Processus		SRV-GMAO	
	Suivi des non-conformités terrain	Information	Stéphane Martin	QMS CloudCert	Stéphane Martin
	Données SAV	Information	Thomas Leroy	SRV-GMAO	Julien Lambert
	Communication client-tech	Processus	Thomas Leroy	WhatsApp	Support SAV
Commercial	Données clients & contrats	Information	Nadia Benamara	SRV-CRM01	Julien Lambert
	CRM et gestion des commandes	Processus & Information			
	Image de marque	Information		Outlook	Tous
	Communication client	Processus		Outlook	
	Conditions de vente	Information		SRV-CRM01	Julien Lambert
	Réponse aux appels d'offres	Processus & Information		Outlook	Tous

1.3 Identification des événements redoutés

Les événements redoutés sont associés aux valeurs métier et se rapportent à l'impact d'une atteinte à un des critères de sécurité de ces valeurs métier (ex : perte de disponibilité ou l'altération d'une fonction assurée par l'objet de l'étude).

L'appréciation du degré de préjudice/impact des événements redoutés est réalisée selon l'échelle de gravité donnée dans l'[annexe n°2](#). Cette échelle doit permettre de comparer objectivement l'importance des missions et des valeurs métier.

Les événements redoutés peuvent être accidentels, environnementaux ou intentionnels. Seuls les événements redoutés intentionnels associés à des attaques « ciblées » seront exploités lors de l'élaboration de scénarios stratégiques.

1.3.1 Événements redoutés liés à des sources malveillantes

Exercice

1.3.2 Événements redoutés liés exclusivement à des sources accidentelles

Sources accidentelles :

- Source humaine interne, sans intention de nuire : employé inattentif
- Source humaine externe, sans intention de nuire : client, partenaire, FAI, hébergeur
- Phénomène naturel : canicule, foudre
- Catastrophe naturelle : inondation, pandémie
- Événements internes : panne de courant, incendie des locaux

Certains événements redoutés peuvent trouver leur source aussi bien dans des sources accidentelles que malveillantes. Ils sont inclus dans le tableau de [§ 1.3.1](#)

Valeur métier	ID	Nom	Description, sources de risque	Impacts	Gravité
Ensemble des VM	ER14	Destruction de la salle serveur	Incendie	Missions, Image et confiance Financier, Juridique	Critique
...	ER15	Arrêt des serveurs de la salle serveur	Panne de courant	- Image et confiance	Significatif
...	ER16	Panne informatique sur le serveur de données	Panne d'informatique		Significatif
Ensemble des VM	ER17	Indisponibilité de plus de 25% des effectifs	Pandémie		Critique

1.4 Socle de sécurité – Référentiels applicables

L'objectif de ce paragraphe est de lister les différents référentiels applicables au système, et d'identifier les éventuels écarts d'application des mesures de sécurité imposées/préconisées pour le système au cours de ses différentes phases de vie.

Réf.	Désignation	Ecart d'application

Etudier l'ajout des référentiels liés au traitement des données de santé (campagne de numérisation de documents issus d'établissements de santé).

Une présentation détaillée des écarts par rapport aux référentiels est disponible dans les annexes n°3 et n°4.

2. TRAITEMENT DU RISQUE

2.1 Stratégie et appétence au risque et objectifs de sécurité

Pour chaque scénario de risque, des seuils d'acceptation du risque et un niveau de sécurité à atteindre en cas de non-acceptation ont été déterminés. Ces décisions se formalisent dans la stratégie de traitement du risque présentée ci-dessous.

Niveau de risque	Acceptabilité du risque	Intitulé des décisions et des actions
Faible	Acceptable en l'état	Aucune action n'est à entreprendre.
Moyen	Tolérable sous contrôle	Un suivi en termes de gestion du risque est à mener et des actions sont à mettre en place dans le cadre d'une amélioration continue sur le moyen et long terme.
Elevé	Inacceptable	Des mesures de réduction du risque doivent impérativement être prises à court terme. Dans le cas contraire, toute ou une partie de l'activité sera refusée.

Le tableau ci-après présente la matrice d'appétence aux risques utilisée pour cette analyse.

		Vraisemblance			
		Peu vraisemblable	Vraisemblable	Très vraisemblable	Quasi certain
Gravité	Mineur				
	Significative				
	Grave				
	Critique				

2.2 Synthèse des scénarios de risques

La synthèse de l'ensemble des scénarios de risques identifiés lors de l'étude est représentée dans la grille présentée ci-dessous. Cette représentation constitue la cartographie du risque initial avant application des mesures du PACS.

2.2.1 Rappel des événements redoutés

2.2.2 Risques retenus

ID	Nom	SR ⁴	Impacts	Gravité	Vraisemblance	Niveau de risque	Stratégie de traitement
R01	Vol d'un document original	Vengeur, Concurrent	Financier, Juridique, Image et confiance	Grave	Vraisemblable		Réduction, transfert
R02							
R03							
R04							

⁴ Source de Risque

ID	Nom	SR ⁴	Impacts	Gravité	Vraisemblance	Niveau de risque	Stratégie de traitement
R09							

Risques d'origine accidentel

R05	Destruction des locaux par incendie		Mission, Financier	Critique	Peu vraisemblable		Réduction, transfert
R06	Panne de courant		Mission	Significatif	Peu vraisemblable		Acceptation
R07	Panne informatique		Mission	Significatif	Très vraisemblable		Réduction, transfert
R08	Pandémie (-25% des effectifs)		Mission, Financier	Grave	Très vraisemblable		Réduction

2.2.3 Matrice des risques

		Vraisemblance			
		Peu vraisemblable	Vraisemblable	Très vraisemblable	Quasi certain
Gravité	Mineur				
	Significative				
	Grave		R01		
	Critique				

2.3 Identification des mesures de sécurité de traitement du risque – Plan d'Amélioration Continue de la Sécurité (PACS)

2.3.1 Fiches de risque résiduel

Remarque : seules les mesures les plus importantes, les plus spécifiques sont mentionnées dans les fiches de risques. L'ensemble des mesures est visualisable dans le document LUMINIS ECLAIRAGE_plan_action.pdf.

Ces mesures ont un impact direct sur la gravité et la vraisemblance (baisse / réduction).

RR01 – Vol d'un document original par un collaborateur mécontent ou un concurrent		
Description et analyse du risque résiduel : Le risque résiduel est principalement lié au facteur humain.		
Événements redoutés concernés : ER4 - Vol d'un document original		
Mesures de traitement du risque existantes et complémentaires : - Habilitation des personnels pour le traitement des documents sensibles - Sensibilisation des personnels impliqués au début de chaque campagne - Sécuriser l'accès au locaux (contrôle d'accès, alarme) - Mettre en place un cahier de visite - Stockage sécurisé des documents sensibles - Procédure formelle de gestion des documents originaux sensibles - Assurance en cas de vol		
Evaluation du risque résiduel		
Gravité initiale : 3/4	Vraisemblance initiale : 2/4	Niveau de risque initial
Gravité résiduelle : 2/4	Vraisemblance résiduelle : 1/4	Niveau de risque résiduel
Gestion du risque résiduel : Contrôle périodique de la bonne mise en œuvre des procédures.		

2.3.2 Synthèse des risques résiduels

		Vraisemblance			
		Peu vraisemblable	Vraisemblable	Très vraisemblable	Quasi certain
Gravité	Mineur				
	Significative	RR01			
	Grave		R01		
	Critique				

DOCUMENT D'EXERCICE

- Annexe n°1 : critères de sécurité et échelles des besoins de sécurité

○ Critères de sécurité

Critère	Echelle de besoin de sécurité	Description
Disponibilité	Échelle de disponibilité	Propriété d'accessibilité au moment voulu des valeurs métiers.
Intégrité	Échelle d'intégrité	Propriété d'exactitude et de complétude des valeurs métiers.
Confidentialité	Échelle de confidentialité	Propriété des valeurs métiers de n'être accessibles qu'aux utilisateurs autorisés.
Traçabilité	Échelle de traçabilité	Propriété d'une valeur métier permettant de retrouver, avec une confiance suffisante, les circonstances dans lesquelles elle évolue.

○ Échelles des besoins de sécurité

Les échelles suivantes sont utilisées pour exprimer les besoins de sécurité en termes de confidentialité, intégrité et de disponibilité.

Intégrité

Niveau	Nom	Description
1	DéTECTABLE	La VM ⁵ peut ne pas être intègre si l'altération est identifiée.
2	Maîtrisé	La VM peut ne pas être intègre si l'altération est identifiée et l'intégrité de la valeur métier retrouvée.
3	Intègre	La VM doit être rigoureusement intègre.
4	Opposable	Preuve

Confidentialité

Niveau	Nom	Description
1	Public	La valeur métier est publique.
2	Limité	La VM ne doit être accessible qu'au collaborateur et aux partenaires.
3	Réservé	La VM ne doit être accessible qu'au collaborateur (interne) impliqué.
4	Privé	La VM ne doit être accessible qu'à des personnes identifiées et ayant le besoin d'en connaître.

Disponibilité

Niveau	Nom	Description
1	Plus de 48 h	La valeur métier peut être indisponible plus de 48 heures.
2	Entre 24 et 48 h	La valeur métier doit être disponible dans les 48 heures.
3	Entre 12 et 24 h	La valeur métier doit être disponible dans les 24 heures.
4	Moins de 12 h	La valeur métier doit être disponible dans les 12 heures.

⁵ Valeur Métier

- Annexe n°2 : échelle de gravité

Gravité	Description détaillée de l'échelle
Mineure (1/4)	Aucun impact opérationnel ni sur les performances de l'activité ni sur la sécurité des personnes et des biens. La société surmontera la situation sans trop de difficultés (consommation des marges).
Significative (2/4)	Dégradation des performances de l'activité sans impact sur la sécurité des personnes et des biens. La société surmontera la situation malgré quelques difficultés (fonctionnement en mode dégradé).
Grave (3/4)	Forte dégradation des performances de l'activité, avec d'éventuels impacts significatifs sur la sécurité des personnes et des biens. La société surmontera la situation avec de sérieuses difficultés (fonctionnement en mode très dégradé).
Critique (4/4)	Incapacité pour la société d'assurer tout ou partie de son activité, avec d'éventuels impacts graves sur la sécurité des personnes et des biens. La société ne surmontera vraisemblablement pas la situation (sa survie est menacée).

Annexe n°3 : état d'application du guide d'hygiène informatique de l'ANSSI

Statut d'application de la mesure

Pas mise en œuvre
Partiellement mis en œuvre
Majoritairement mise en œuvre
Totalement mis en œuvre

ID	Mesure	Statut	Ecart(s) relevé(s)	Commentaires
1	Former les équipes opérationnelles à la sécurité des systèmes d'information	Pas mise en œuvre	[NC-1] Les équipes opérationnelles ne suivent pas de formations à la cybersécurité. [NC-6] Les équipes opérationnelles ne sont pas régulièrement formées. [NC-39] Les développeurs ne sont pas suffisamment sensibilisés à la cybersécurité	
2	...			

- Annexe n°4 : état d'application du RGPD

Par rapport au scope retenu pour l'analyse de risques, les données personnelles sont réparties dans les applications suivantes :

Application	Finalité	Données	Commentaires
Application X			
Google Workspace		Saisie libre qui laisse la possibilité de saisir « par accident » des données sensibles (par exemple : handicap)	

Application du RGPD

Globalement, le RGPD n'est pas appliqué dans l'entreprise :

- Il n'existe pas de responsable formellement désigné ;
- Il existe un registre des traitements mais il est incomplet et, pour les traitements existants, il est peu renseigné et n'est pas à jour

Le tableau ci-dessus présente un état d'application des mesures attendues dans le cadre du RGPD. Un effort est fait sur application X qui est l'application cible. A terme, les informations contenues dans Google WS seront marginales.

Statut d'application de la mesure

Non appliquée
Partiellement mis en œuvre
Appliquée avec restrictions
Appliquée sans restrictions

ID	Mesures	Buts	Statut	Commentaires
1	Finalités : déterminées, explicites et légitimes	Garantir la proportionnalité et la nécessité du traitement	Non appliquée	Finalités trop sommaires
2	Fondement : licéité du traitement, interdiction du détournement de finalité	Garantir la proportionnalité et la nécessité du traitement	Non appliquée	Finalités trop sommaires, pas de références vers des documents réglementaires (durées réglementaires de rétention)
3	...			

Annexe n°5 : Glossaire méthode EBIOS Risk Manager

ANSSI : Agence Nationale de la Sécurité et des Systèmes d'Information

Action élémentaire : action unitaire exécutée par une source de risque sur un bien support dans le cadre d'un scénario opérationnel.

Exemples : exploiter une vulnérabilité, envoyer un mail piégé, effacer des traces, augmenter des privilèges.

Besoins de sécurité : propriété de sécurité à garantir pour une valeur métier. Elle traduit un enjeu de sécurité pour la valeur métier.

Exemples : disponibilité, intégrité, confidentialité, traçabilité.

Biens support : composante du système d'information sur laquelle repose une ou plusieurs valeurs métier. Un bien support peut être de nature numérique, physique ou organisationnelle.

Exemples : serveur, local technique, dispositif de vidéo protection, administrateurs.

Biens support critique : bien support susceptible d'être ciblé par une source de risque pour atteindre son objectif. Les biens supports critiques sont ceux qui apparaissent dans les scénarios opérationnels.

Cartographie de menace numérique de l'écosystème : représentation visuelle du niveau de menace numérique des parties prenantes de l'écosystème vis-à-vis de l'objet étudié.

Cartographie du risque : représentation visuelle des risques issus des activités d'appréciation du risque.

Chemin d'attaque : suite d'événements distincts que la source de risque devra probablement générer pour atteindre son objectif. Cette terminologie concerne les scénarios stratégiques.

Événement intermédiaire : dans la séquence d'un scénario stratégique, un événement intermédiaire peut être généré par la source de risque à l'égard d'une partie prenante de l'écosystème en vue de faciliter l'atteinte de son objectif.

Événement redouté : un événement redouté est associé à une valeur métier et porte atteinte à un critère ou besoin de sécurité de la valeur métier (exemple : indisponibilité d'un service, modification illégitime de données, divulgations de données classifiées). Les événements redoutés à exploiter sont ceux des scénarios stratégiques et se rapportent à l'impact d'une attaque sur une valeur métier. Chaque événement redouté est évalué selon le niveau de gravité des conséquences, à partir d'une métrique.

Gravité : estimation du niveau et de l'intensité des effets d'un risque. La gravité fournit une mesure des impacts préjudiciables perçus, qu'ils soient directs ou indirects.

Menace : terme générique utilisée pour désigner toute intention hostile de nuire dans le cyber espace. Une menace peut être ciblée ou non sur l'objet de l'étude.

Mesures de sécurité : moyen de traiter un risque prenant les formes de solutions ou d'exigences pouvant être inscrite dans un contrat.

Nota : une mesure peut être d'ordre fonctionnel, technique ou organisationnel ; elle peut agir sur une valeur métier, un bien support, une partie prenante de l'écosystème, certaines mesures peuvent se renforcer mutuellement en agissant selon les axes complémentaires (gouvernance, protection, défense, résilience).

Mission : fonction, finalité, raison d'être de l'objet de l'étude

Mode opératoire : suite d'actions élémentaires que la source de risque devra probablement réaliser pour atteindre son objectif. Cette terminologie concerne les scénarios opérationnels.

Niveau de menace d'une partie prenante : donne une mesure du potentiel de risque que fait peser une partie prenante de l'écosystème sur l'objet de l'étude, compte tenu de son interaction avec lui, de sa vulnérabilité, de son exposition au risque, de sa fiabilité, etc.

...